MacZine

THE MACTECH SOLUTIONS NEWSLETTER
ISSUE Nº 070 · NOVEMBER 2026 · MACTECHSOLUTIONSLLC.COM/MACZINE

COUNTER-ARGUMENT · CONFIGURATION MANAGEMENT

Every Patch Is a Change, and 3.4.3 Wants the Ticket to Prove It

NIST 800-171 change control, 3.4.3 and 3.4.4, is worth 1 SPRS point each and easy to defer. Why a small shop should not, and what the ticket must show.

BY MAXINE

READING TIME · 5 MIN

NIST-800-171 · CONFIGURATION-MANAGEMENT · CHANGE-CONTROL · CMMC-LEVEL-2

Change control is the requirement small defense contractors most often decide they can afford to leave unfinished, and on the arithmetic alone they have a case. NIST SP 800-171 requirement 3.4.3, to track, review, approve or disapprove, and log changes to organizational systems, carries 1 point in the DoD Assessment Methodology. Its companion, 3.4.4, to analyze the security impact of changes prior to implementation, carries 1 more. Both sit under the point ceiling that 32 CFR 170.21(a)(2) sets for a Level 2 POA&M, and neither is among the six requirements that rule bars outright. For a twenty-person shop with one administrator, a change control process can look like a large-company ritual bought at a small-company price.

That case deserves a fair hearing before it is turned down, because it is not wrong about the numbers. It is wrong about what the two requirements cover and about what they hold up.

FIELD COPY
ISSUE Nº 070
NIST 800 171

1

SPRS POINT EACH ON 3.4.3, TRACK AND LOG CHANGES, AND 3.4.4, ANALYZE THEIR SECURITY IMPACT FIRST

The case for leaving it on the POA&M

Put the argument at its strongest. Two points out of 110 will not, on their own, decide whether a program clears the 88-point floor for Conditional status. The POA&M eligibility rules allow both items to be carried, with 180 days to close them. The administrator already knows what changed last week. Writing it down feels like paperwork that protects nobody.

Three things undercut it. First, the score posted to SPRS stays lower for as long as the gap is open: a POA&M defers the closeout, not the deduction, as the eligibility piece made plain. Second, the 180 days are a deadline, not a grace period. A program that could not find time for tickets before its assessment has to find it under a clock that ends its conditional status if it slips.

Third, and this is the one the arithmetic hides, change control is the record the rest of the configuration family leans on. The baseline piece named change tickets as one of the four artifacts an assessor asks for when reviewing a configuration baseline, the record that ties each deviation back to a decision someone made on purpose. Without the tickets, a baseline is a document about the day it was written.

4

ASSESSMENT OBJECTIVES ON 3.4.3, TRACKED, REVIEWED, APPROVED OR DISAPPROVED, AND LOGGED, AND EACH MUST BE MET

5

SPRS POINTS ON 3.4.5, RESTRICTING WHO MAY MAKE CHANGES AT ALL, TOO HEAVY TO CARRY ON A POA&M

What the four objectives ask of a ticket

The requirement is a sequence of verbs, and NIST SP 800-171A turns each into its own objective: changes are tracked, reviewed, approved or disapproved, and logged. Every one must be met, and missing any one costs the full point.

The scope is wider than most small programs assume. The Rev 2 discussion of 3.4.3 includes changes to configuration settings on "operating systems, applications, firewalls, routers, and mobile devices," along with "unscheduled and unauthorized changes" and "changes to remediate vulnerabilities." That last phrase puts the monthly patch cycle inside the requirement. A shop that writes tickets for new servers but not for patches is tracking a fraction of what 3.4.3 names.

A ticket that answers all four objectives is short but complete. It says what is changing and on which systems, who asked for it and why, who reviewed it, the decision with a name and a date, when the change was carried out, and where the log shows that it happened. The discussion is specific about that last part: audit logs of changes "include activities before and after changes are made." The ticket should point into the same records the 3.3.1 audit log piece described, not sit beside them as a second story.

The word disapproved does work of its own. Objective 3.4.3[c] asks whether changes are approved or disapproved, and a queue in which nothing has ever been refused is hard to tell apart from a queue nobody reviews. A recorded refusal, with its reason, is among the more persuasive pages a small program can show.

The audit log proves a change happened. Only the ticket proves someone meant it to.

◆ THE BOARD IS OPTIONAL, THE DECISION IS NOT

The interview list for 3.4.3 names "members of change control board or similar," and the examine list offers board minutes as one artifact among many. Nothing in the requirement makes a twenty-person shop convene a board. What objective 3.4.3[c] does need is a recorded decision, approved or disapproved, by whoever the procedure names.

Prior to implementation is a timestamp

3.4.4 has a single assessment objective, and it turns on three words: the security impact of changes is analyzed "prior to implementation." An assessor reading change records can check that from the dates alone. An analysis written after the change went in, however careful, does not meet the plain words of the objective.

The analysis does not need to be long. The Rev 2 discussion describes it as reviewing the security plan to understand the requirements, reviewing system design documentation to see how a change might affect the controls, and, where the stakes justify it, a risk assessment to decide whether additional controls are required. For a new firewall rule, that can be two sentences inside the ticket: which requirements the rule touches, which section of the system security plan describes them, and whether the plan now needs an update. The discussion also says who should write it: people with information security responsibilities, such as system administrators and security officers, who have the skill to see the security consequences.

Emergency changes are where small shops most often break this. The objective offers no exception for urgency. A workable procedure gives emergencies a fast path that still records a short analysis before the change, even a single line from the person making it, and sends the ticket to full review afterward. What a program cannot afford is to let "we will write it up later" become the routine.

The heavier neighbor makes the same point from the other side. 3.4.5, which restricts who may make changes in the first place, carries 5 points, so the eligibility rule keeps it off a POA&M entirely. A program that locks down who can change its systems but keeps no record of what they changed has secured the door and thrown away the visitor log.

The place to start is the next patch cycle. One ticket, opened before the patches go in, naming the systems they touch and the requirements they affect, approved by a person with a name, and closed with a pointer to the log that shows they landed. Two points come back with it, and the baseline gains what it never had on its own: a record of its own history. ◆